

I am building a Defensive Retrieval-Augmented Generation (RAG) system for legal firms as a final-year Artificial Intelligence and Machine Learning engineering project.

Current Architecture

Local LLM (Meta Llama) LangChain / LangGraph orchestration PostgreSQL + pgvector vector database Microsoft Presidio NVIDIA NeMo Guardrails FastAPI backend Docker deployment React frontend

The objective is to build a production-grade secure legal assistant that can withstand adversarial inputs while maintaining legal accuracy, privacy, explainability, and trustworthy retrieval.

I already understand common topics such as:

Prompt Injection Jailbreaks Hallucination Basic Guardrails Basic Retrieval

Please DO NOT recommend introductory papers on these topics.

Instead, identify advanced and recent peer-reviewed research (2023–2026) that investigates less commonly implemented defensive mechanisms for RAG systems, especially in enterprise or legal environments.

I want papers that could inspire new security modules for my GitHub repository.

Advanced Defensive Mechanisms for Secure RAG Systems

Recent research (2023–2026) describes several underutilized defensive mechanisms for RAG systems that go beyond basic guardrails, spanning cryptographic retrieval, adaptive defense orchestration, zero-trust architectures, and provenance-based policy enforcement (■ Zhou et al., 2025; ■ Pallerla et al., 2026; Nandagopal, 2025; Boggarapu, 2026).

Cryptographic and Encryption-Based Retrieval Defenses

Pre-storage full-encryption schemes protect both retrieved content and vector embeddings, guaranteeing that only authorized entities access data and providing formally verified confidentiality and integrity under a computational security model (■ Zhou et al., 2025). This provably secure framework (SAG) resists state-of-the-art attacks and addresses the limited interpretability and lack of formal guarantees in heuristic filtering approaches (■ Zhou et al., 2025). Homomorphic encryption applied within federated learning safeguards model parameters and mitigates data leakage during collaborative retriever training across organizations (Mao et al., 2025). Input-side defense taxonomies also identify homomorphic encryption retrieval and adversarial pre-filtering as distinct data protection mechanisms for the retrieval stage (Mu et al., 2026).

Defense Mechanism	Pipeline Stage	Security Guarantee	Source
Pre-storage full encryption	Retrieval + storage	Confidentiality & integrity (formal proof)	(■ Zhou et al., 2025)
Homomorphic encryption	Federated retriever training	Parameter privacy, leakage mitigation	(Mao et al., 2025)

Defense Mechanism	Pipeline Stage	Security Guarantee	Source
Adversarial pre-filtering	Input stage	Data poisoning prevention	(Mu et al., 2026)

FIGURE 1 Comparison of cryptographic defense mechanisms for RAG retrieval and storage stages.

Adaptive and Context-Aware Defense Orchestration

Enabling all defenses simultaneously incurs a substantial utility cost, reducing contextual recall by more than 40% (■ Pallerla et al., 2026). The **Sentinel-Strategist architecture** addresses this trade-off through a context-aware framework where a Sentinel detects anomalous retrieval behavior and a Strategist selectively deploys only the defenses warranted by the query context (■ Pallerla et al., 2026). This adaptive approach eliminates membership inference leakage while restoring contextual recall to more than 75% of the undefended baseline under data poisoning attacks (■ Pallerla et al., 2026). The **ControlNET firewall** leverages activation shift phenomena to detect adversarial queries and mitigate their impact through semantic divergence, achieving over 0.909 AUROC across benchmarks including FinQA and MedicalSys (■ Yao et al., 2025). ControlNET enforces role-based access control on retrieval, preventing unauthorized cross-domain data access such as a doctor retrieving financial records (■ Yao et al., 2025).

Zero-Trust Architecture and Policy Enforcement

A zero-trust framework mandates continuous verification of all entities within the data flow, mitigating unauthorized access and lateral movement through micro-segmentation and immutable system prompts (Nandagopal, 2025). **Salted sequence tagging** fortifies systems against prompt injection by structurally separating system instructions from user-supplied content (Nandagopal, 2025). A two-plane architecture separating the data plane from the control plane enables identity-aware filtering and attribute-based access control mediated by policy-as-code frameworks like Open Policy Agent (Boggarapu, 2026). Provenance evidence bundles meeting IEEE P7001 transparency standards support auditability, while ongoing assessment measures leakage rate, entitlement violation rate, and provenance fidelity against the NIST AI RMF (Boggarapu, 2026).

Privacy-Preserving PII Extraction Defenses

The **SEAL-Tag** framework introduces a Verify-then-Route paradigm that generates a verifiable PII-Evidence Table alongside draft responses, adjudicated by a Probabilistic Circuit enforcing logical constraints for robust decision-making (■ Xie et al., 2026). This approach reduces adaptive PII leakage by over 8× while matching the utility and speed of unsafe baselines, establishing a new Pareto frontier (■ Xie et al., 2026). Knowledge asymmetry exploitation attacks achieve over 91% privacy extraction in single-domain scenarios, highlighting the urgency of such defenses (■ Chen et al., 2025). Output-side defense taxonomies identify differential privacy perturbation, federated learning isolation, and lightweight data sanitization as complementary leakage prevention techniques (Mu et al., 2026). The **SecMulti-RAG** framework selectively routes queries to external LLMs only when prompts are deemed safe by a filtering mechanism, preventing proprietary data exposure in enterprise settings (Byun et al., 2025).

Legal Domain Considerations

Legal RAG systems face unique retrieval challenges including jurisdiction-aware multifaceted queries where neural retrieval struggles with contextual precision, occasionally returning semantically similar but legally irrelevant cases (Oche et al., 2025). Document length and context window limitations risk omitting crucial legal nuances during summarization, potentially misleading practitioners (Oche et al., 2025). RAG mitigates fabricated citation risk by ensuring assertions trace directly to verified sources, a critical safeguard given professional consequences of citing nonexistent cases (Oche et al., 2025). The **RobustRAG** isolate-then-aggregate strategy computes LLM responses for each retrieved passage in isolation before securely aggregating them, protecting against retrieval corruption where as few as 10 poisoned paragraphs (0.04% of corpus) achieve 98.2% attack success (Zhou et al., 2024). Black-box poisoning attacks like CPA-RAG achieve over 90% success at top-5 retrieval and compromise commercial platforms, underscoring the need for robustness-aware retrieval in legal deployments (■ Li et al., 2025).

These search results were found and analyzed using Consensus, an AI-powered search engine for research. Try it at <https://consensus.app>. © 2026 Consensus NLP, Inc. Personal, non-commercial use only; redistribution requires copyright holders' consent.

References

- Boggarapu, N. B. (2026). Secure Retrieval-Augmented Generation: Preventing Data Leakage with Provenance and Policy Enforcement. *Computer Fraud and Security*. <https://doi.org/10.52710/cfs.976>
- Byun, G., Lee, S., Choi, N., & Choi, J. D. (2025). Secure Multifaceted-RAG: Hybrid Knowledge Retrieval with Security Filtering. *Inf.*, 16, 804. <https://doi.org/10.3390/info16090804>
- Chen, Y., Wang, Y., Zhang, H., & Gu, T. (2025). Fine-Grained Privacy Extraction from Retrieval-Augmented Generation Systems via Knowledge Asymmetry Exploitation. *ArXiv*, abs/2507.23229. <https://doi.org/10.48550/arxiv.2507.23229>
- Li, C., Zhang, J., Cheng, A., Z., Li, X., & J. (2025). CPA-RAG:Covert Poisoning Attacks on Retrieval-Augmented Generation in Large Language Models. *ArXiv*, abs/2505.19864. <https://doi.org/10.48550/arxiv.2505.19864>
- Mao, Q., Zhang, Q., Hao, H., Han, Z.-H., Xu, R., Jiang, W., Hu, Q., Chen, Z., Zhou, T., Li, B., Song, Y., Dong, J., Li, J., & Yu, P. S. (2025). Privacy-Preserving Federated Embedding Learning for Localized Retrieval-Augmented Generation. *ArXiv*, abs/2504.19101. <https://doi.org/10.48550/arxiv.2504.19101>
- Mu, Y., Hu, H., Li, F., Yuan, Q., Wu, J., Liu, Z., Liu, P., Wang, M., Zhou, H., & Liu, Y. (2026). Towards Secure Retrieval-Augmented Generation: A Comprehensive Review of Threats, Defenses and Benchmarks. *ArXiv*, abs/2603.21654. <https://doi.org/10.48550/arxiv.2603.21654>
- Nandagopal, S. (2025). Securing Retrieval-Augmented Generation Pipelines: A Comprehensive Framework. *Journal of Computer Science and Technology Studies*. <https://doi.org/10.32996/jcsts.2025.7.1.2>
- Oche, A. J., Folashade, A. G., Ghosal, T., & Biswas, A. (2025). A Systematic Review of Key Retrieval-Augmented Generation (RAG) Systems: Progress, Gaps, and Future Directions. *ArXiv*, abs/2507.18910. <https://doi.org/10.48550/arxiv.2507.18910>
- Pallerla, P., Bhukya, W. N., Vemula, B., & Kodi, C. R. (2026). Adaptive Defense Orchestration for RAG: A Sentinel-Strategist Architecture against Multi-Vector Attacks. *ArXiv*, abs/2604.20932. <https://doi.org/10.48550/arxiv.2604.20932>
- Xie, J., Li, S., & Cheng, G. (2026). SEAL-Tag: Self-Tag Evidence Aggregation with Probabilistic Circuits for PII-Safe Retrieval-Augmented Generation. *ArXiv*, abs/2603.17292. <https://doi.org/10.48550/arxiv.2603.17292>

Yao, H., Shi, H., Chen, Y., Jiang, Y., Wang, C., & Qin, Z. (2025). ControlINET: A Firewall for RAG-based LLM System. *ArXiv, abs/2504.09593*. <https://doi.org/10.48550/arxiv.2504.09593>

Zhou, P., Feng, Y., & Yang, Z. (2025). Provably Secure Retrieval-Augmented Generation. *ArXiv, abs/2508.01084*. <https://doi.org/10.48550/arxiv.2508.01084>

Zhou, Y., Liu, Y., Li, X., Jin, J., Qian, H., Liu, Z., Li, C., Dou, Z., Ho, T.-Y., & Yu, P. S. (2024). Trustworthiness in Retrieval-Augmented Generation Systems: A Survey. *ArXiv, abs/2409.10102*. <https://doi.org/10.48550/arxiv.2409.10102>